Technical Risk Treatment Lab Report

Field	Detail
Name	Adebukola Olanipekun
Registration Details	C11/26/CGRCE/17603 ,Cohort 11 CGRCE
Date	6th November, 2026

1 Management summary

Decisions and cost

Avoidance for R1; mitigation for R2, R3 and R4; transfer (managed offsite backup) proposed for residual R4 only; plain HTTP acceptance proposed for 14 days on the isolated dummy-data network (simulated). First-year costs: A hardening **$150**, B managed backup **$360**, C TLS **$100**. Recommended combination A + B + C = **$610**. Illustrative backup scenario (all assumptions): baseline ALE $1,000, residual ALE $200, first-year net benefit of B **$440**.

Risk	Strategy	Initial (L×I)	Residual, provisional	Status
R1 Legacy service	Avoidance	4×4 = 16 High	2×4 = 8 Medium	Unverified
R2 Exposed archive	Mitigation	3×4 = 12 High	2×4 = 8 Medium	Configured, unverified
R3 Unauthorised access	Mitigation	4×3 = 12 High	2×3 = 6 Medium	Rule visible, effect untested
R4 Portal content loss	Mitigation + transfer	2×4 = 8 Medium	2×3 = 6 Medium	File-level restore verified

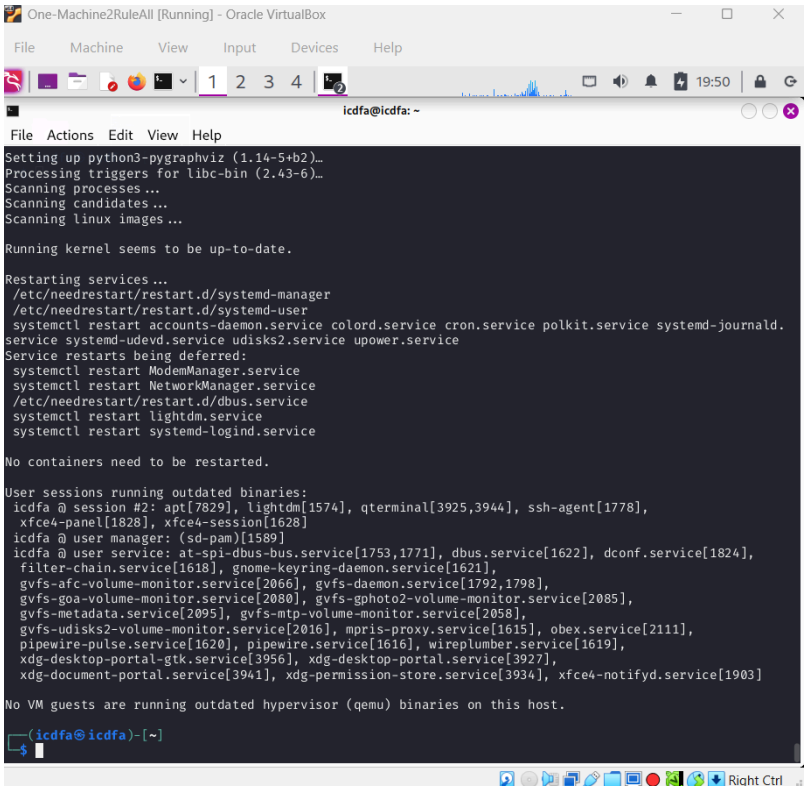


Figure 1. *Package installation output, 19:50 WAT (file sudo_2.png). Step 1.*

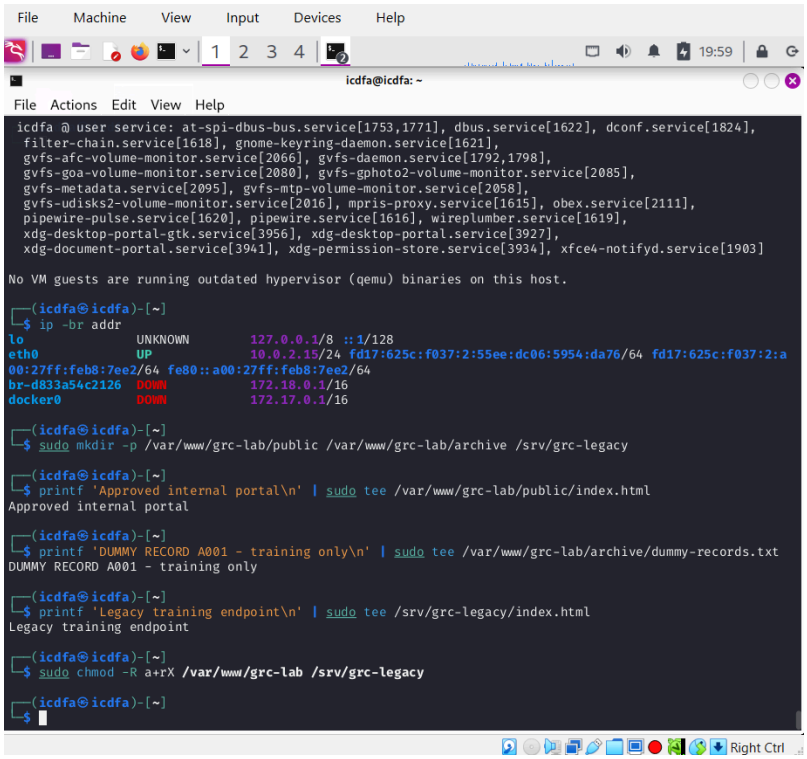
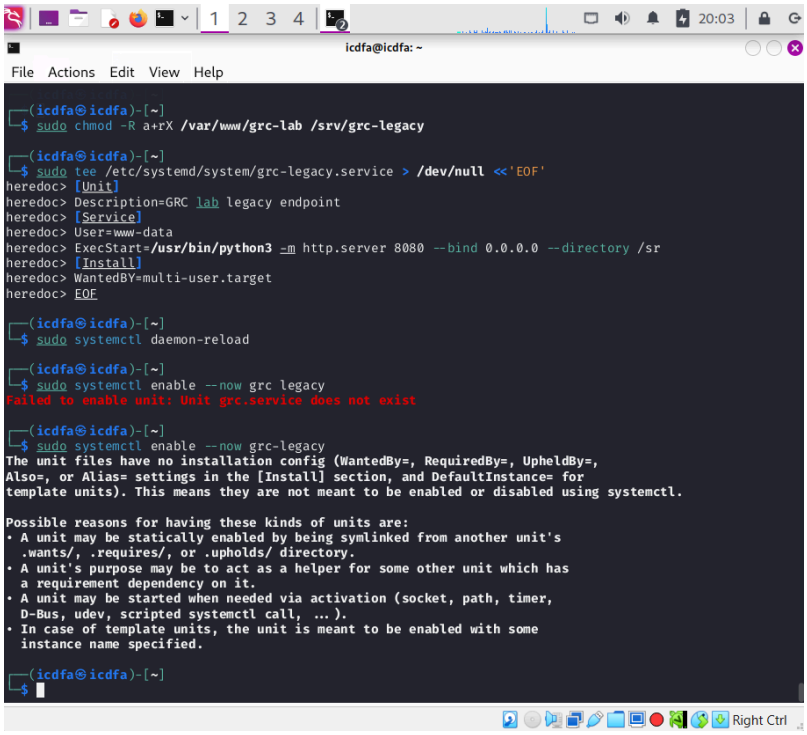
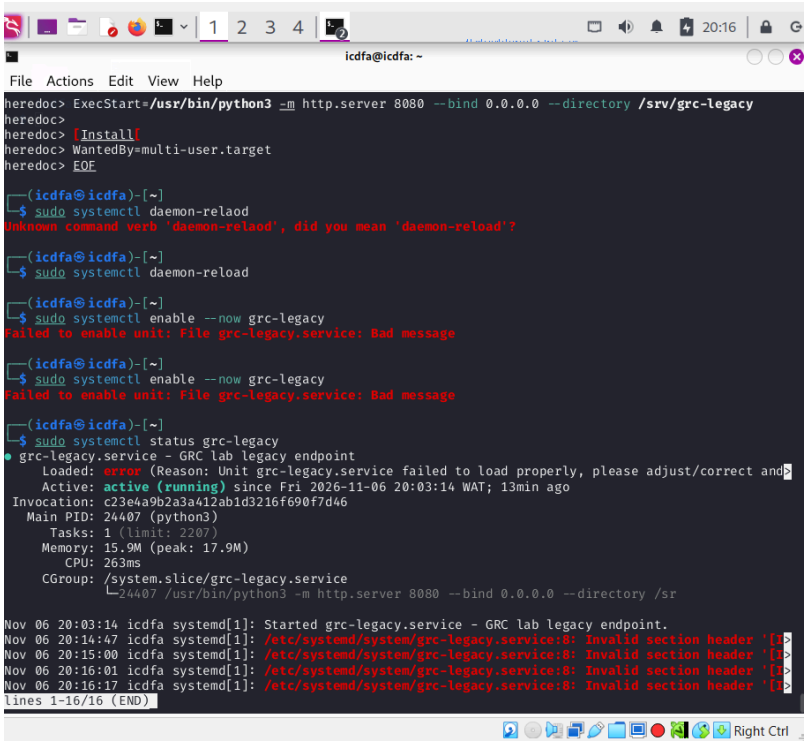
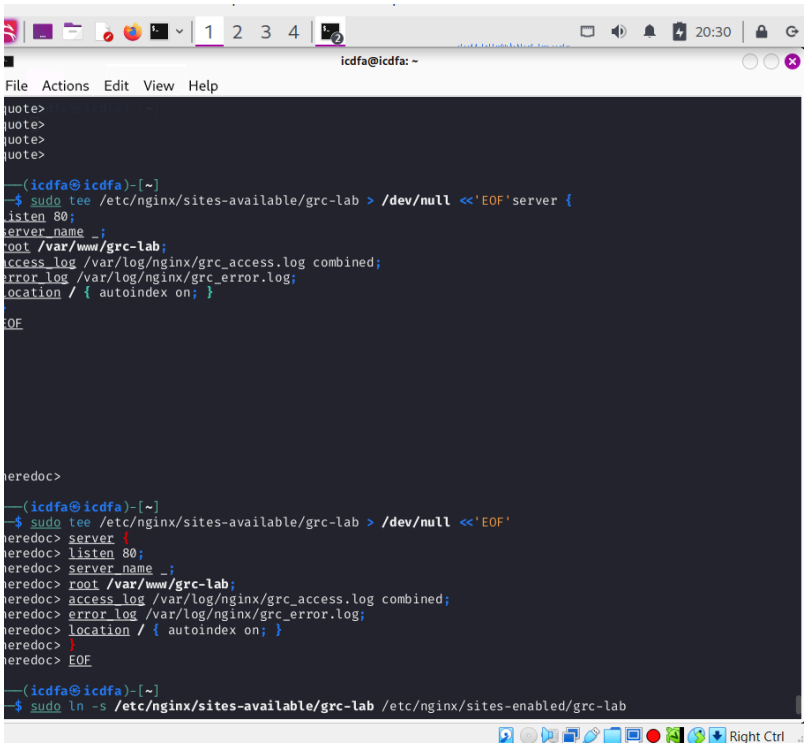
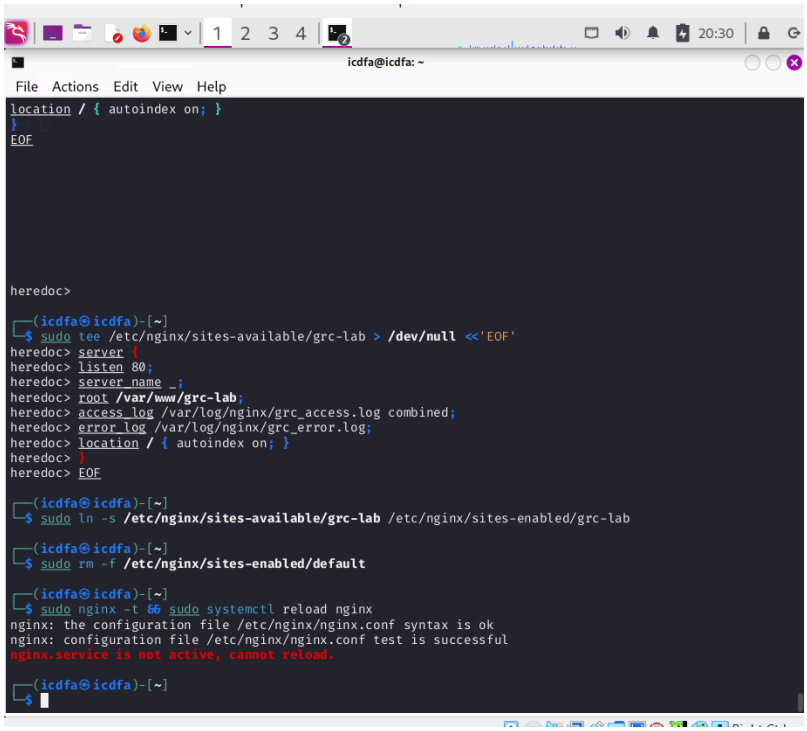


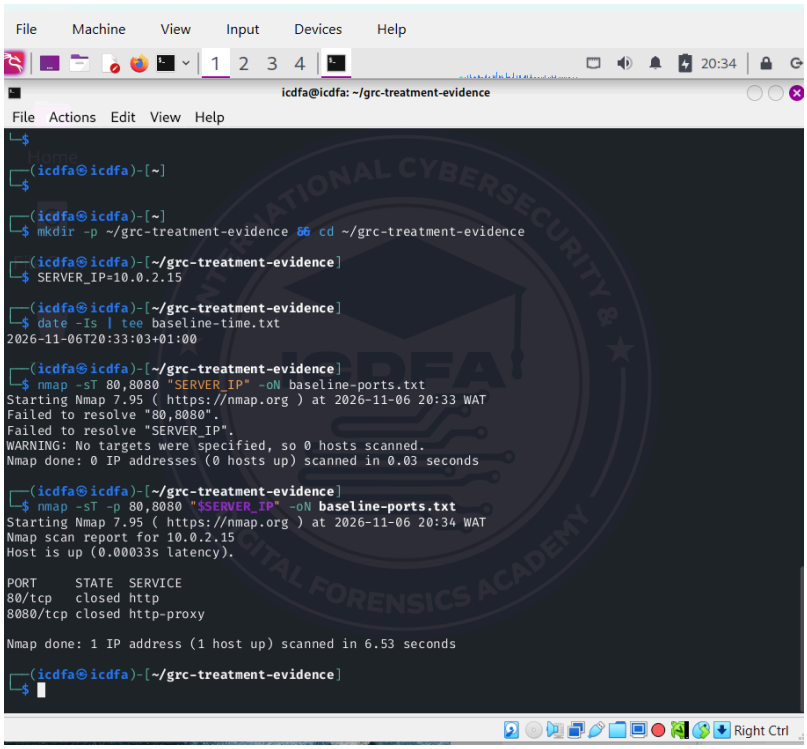
Figure 2. ip -br addr:




icdfa@icdfa: ~
File Actions Edit View Help
heredoc> ExecStart=/usr/bin/python3 -m http.server 8080 --bind 0.0.0.0 --directory /srv/grc-legacy
heredoc>
heredoc> [Install[
heredoc> WantedBy=multi-user.target
heredoc> EOF
┌──(icdfa㉿icdfa)-[~]
└─$ sudo systemctl daemon-relaod
Unknown command verb 'daemon-relaod', did you mean 'daemon-reload'?
┌──(icdfa㉿icdfa)-[~]
└─$ sudo systemctl daemon-reload
┌──(icdfa㉿icdfa)-[~]
└─$ sudo systemctl enable --now grc-legacy
Failed to enable unit: File grc-legacy.service: Bad message
┌──(icdfa㉿icdfa)-[~]
└─$ sudo systemctl enable --now grc-legacy
Failed to enable unit: File grc-legacy.service: Bad message
┌──(icdfa㉿icdfa)-[~]
└─$ sudo systemctl status grc-legacy
● grc-legacy.service - GRC lab legacy endpoint
Loaded: error (Reason: Unit grc-legacy.service failed to load properly, please adjust/correct and
Active: active (running) since Fri 2026-11-06 20:03:14 WAT; 13min ago
Invocation: c23e4a9b2a3a412ab1d3216f690f7d46
Main PID: 24407 (python3)
Tasks: 1 (limit: 2207)
Memory: 15.9M (peak: 17.9M)
CPU: 263ms
CGroup: /system.slice/grc-legacy.service
└─24407 /usr/bin/python3 -m http.server 8080 --bind 0.0.0.0 --directory /sr
Nov 06 20:03:14 icdfa systemd[1]: Started grc-legacy.service - GRC lab legacy endpoint.
Nov 06 20:14:47 icdfa systemd[1]: /etc/systemd/system/grc-legacy.service:8: Invalid section header '[>
Nov 06 20:15:00 icdfa systemd[1]: /etc/systemd/system/grc-legacy.service:8: Invalid section header '[>
Nov 06 20:16:01 icdfa systemd[1]: /etc/systemd/system/grc-legacy.service:8: Invalid section header '[>
Nov 06 20:16:17 icdfa systemd[1]: /etc/systemd/system/grc-legacy.service:8: Invalid section header '[>
lines 1-16/16 (END)
Right Ctrl


icdfa@icdfa: ~
File Actions Edit View Help
quote>
quote>
quote>
quote>
┌──(icdfa㉿icdfa)-[~]
└─$ sudo tee /etc/nginx/sites-available/grc-lab > /dev/null <<'EOF'server {
listen 80;
server_name _;
root /var/www/grc-lab;
access_log /var/log/nginx/grc_access.log combined;
error_log /var/log/nginx/grc_error.log;
location / { autoindex on; }
}
EOF
heredoc>
┌──(icdfa㉿icdfa)-[~]
└─$ sudo tee /etc/nginx/sites-available/grc-lab > /dev/null <<'EOF'
heredoc> server {
heredoc> listen 80;
heredoc> server_name _;
heredoc> root /var/www/grc-lab;
heredoc> access_log /var/log/nginx/grc_access.log combined;
heredoc> error_log /var/log/nginx/grc_error.log;
heredoc> location / { autoindex on; }
heredoc> }
heredoc> EOF
┌──(icdfa㉿icdfa)-[~]
└─$ sudo ln -s /etc/nginx/sites-available/grc-lab /etc/nginx/sites-enabled/grc-lab
Right Ctrl





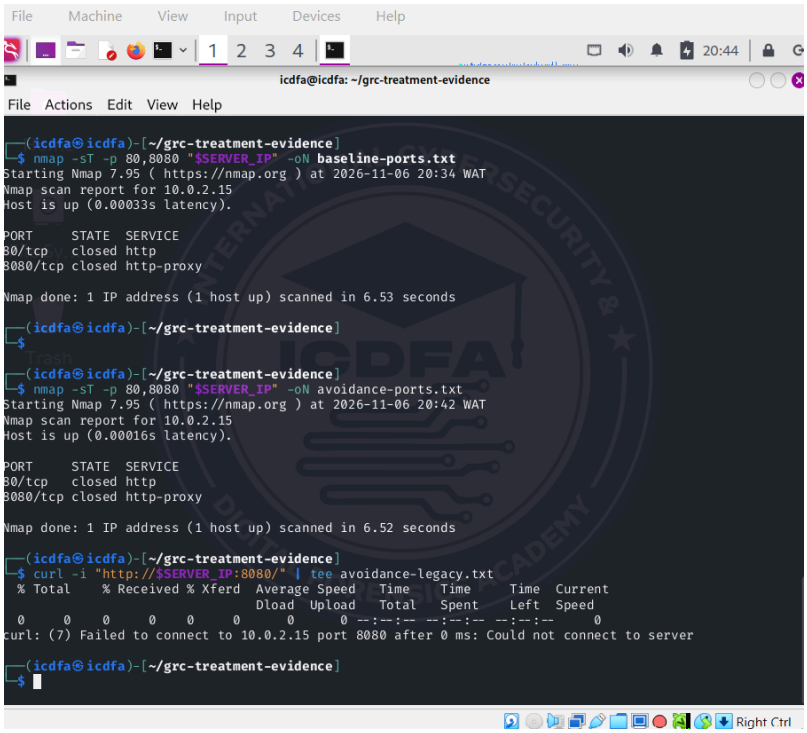
F SERVER_IP=10.0.2.15, .3 Step 5: baseline risk register

ID	Asset	Threat event	Observed weakness
R1	Legacy endpoint (`grc-legacy.service`, TCP 8080)	Unauthorised use or probing of an unmaintained service that the business no longer needs	Listening on `0.0.0.0:8080` with no access control; enabled and running; malformed unit file
R2	Archive of internal records (`/var/www/grc-lab/archive`)	Disclosure through directory listing or a direct file URL	Archive sits inside the web root; `autoindex on` in site config
R3	Approved web service (nginx, TCP 80)	Network access from any unauthorised host	No host firewall restriction before UFW was enabled at ~21:33; pre-change state not captured
R4	Approved portal content (`/var/www/grc-lab/public`)	Accidental or malicious deletion or modification with no way to recover	Single copy; no backup existed until 21:43

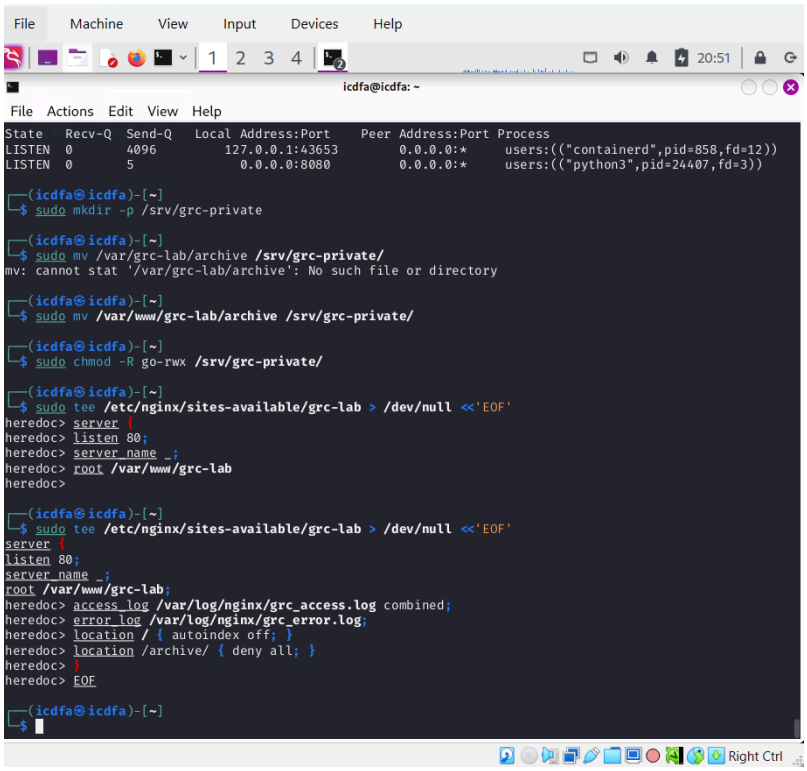
ID	Likelihood	Impact	Score and band	Treatment owner (simulated roles)
R1	4	4	16 – High	Systems Administrator
R2	3	4	12 – High	Document Server Owner
R3	4	3	12 – High	Network / Security Administrator
R4	2	4	8 – Medium	Service and Backup Owner

3.4 Step 6: avoidance of the legacy workflow

Change record	CR-01 (simulated). Retire the unused legacy endpoint on TCP 8080; retain the approved portal on port 80.
Business impact	None expected: no real data, no approved workflow depends on it. The approved portal must remain reachable throughout.
Approval role	IT Operations Manager. **Approval simulated**, 2026-11-06.
Test	`sudo systemctl disable --now grc-legacy`; `systemctl is-active grc-legacy` returns `inactive`; `ss -lntp` shows no 8080 listener; client scan and curl save `avoidance-ports.txt` and `avoidance-legacy.txt`; port 80 still answers.
Rollback	`sudo systemctl enable --now grc-legacy`, test, then reapply the treatment. Final state: legacy endpoint disabled.

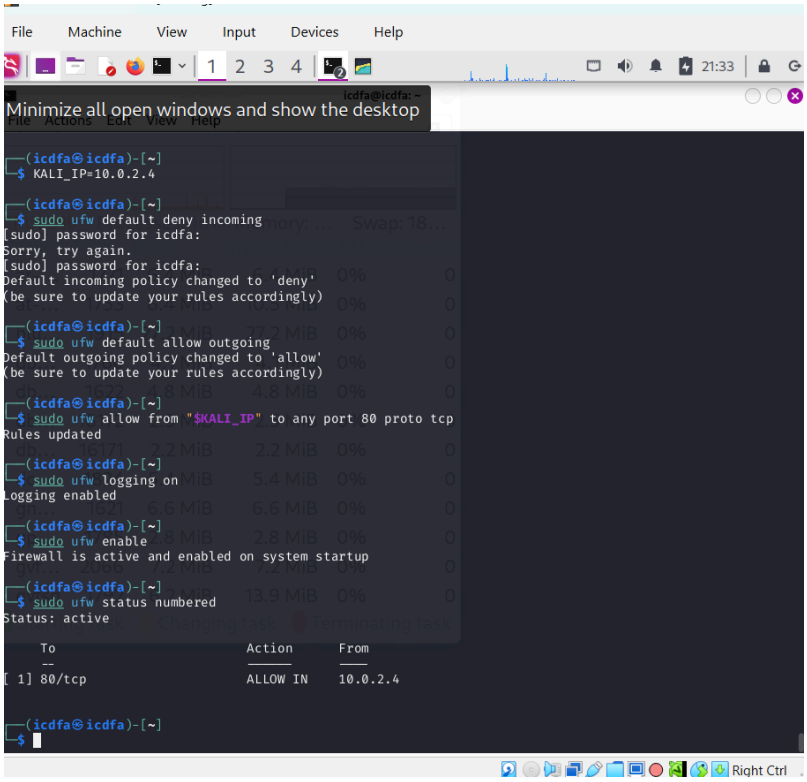


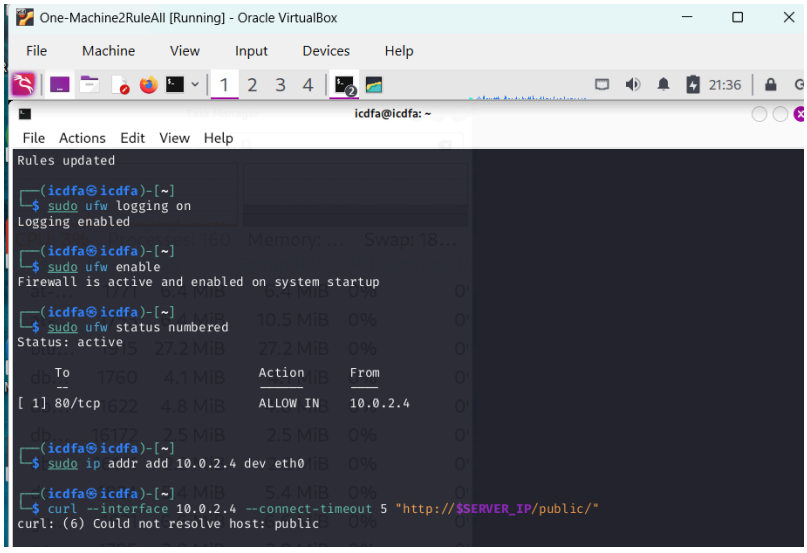
Remove archive publication



Test	Expected
/public/ from client	HTTP 200
/archive/ from client	HTTP 403
/archive/dummy-records.txt from client	HTTP 403
/ from client	HTTP 403 (no root index, listing off)
nginx -t && systemctl reload nginx after the rewrite	syntax OK, reload OK

Restrict network access with UFW



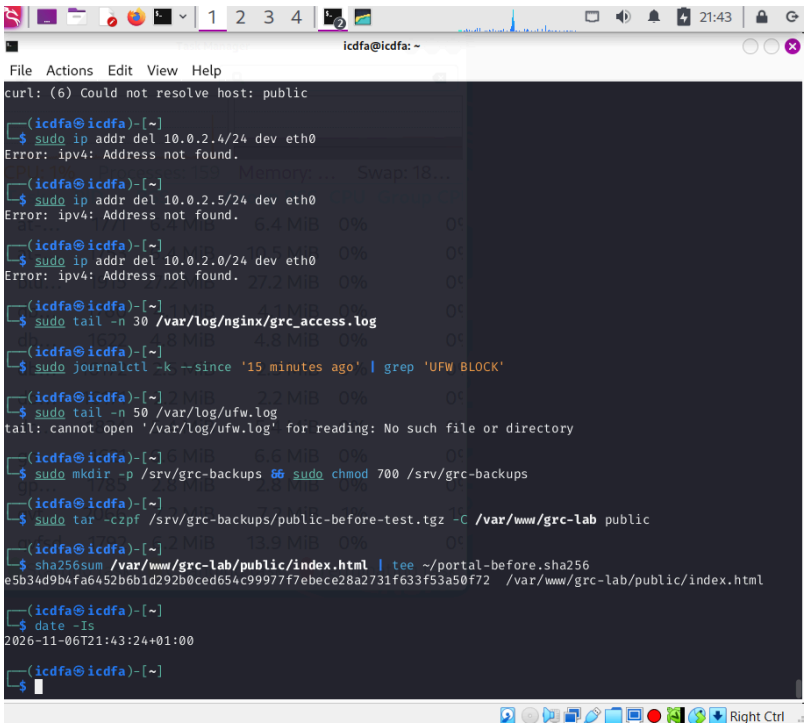


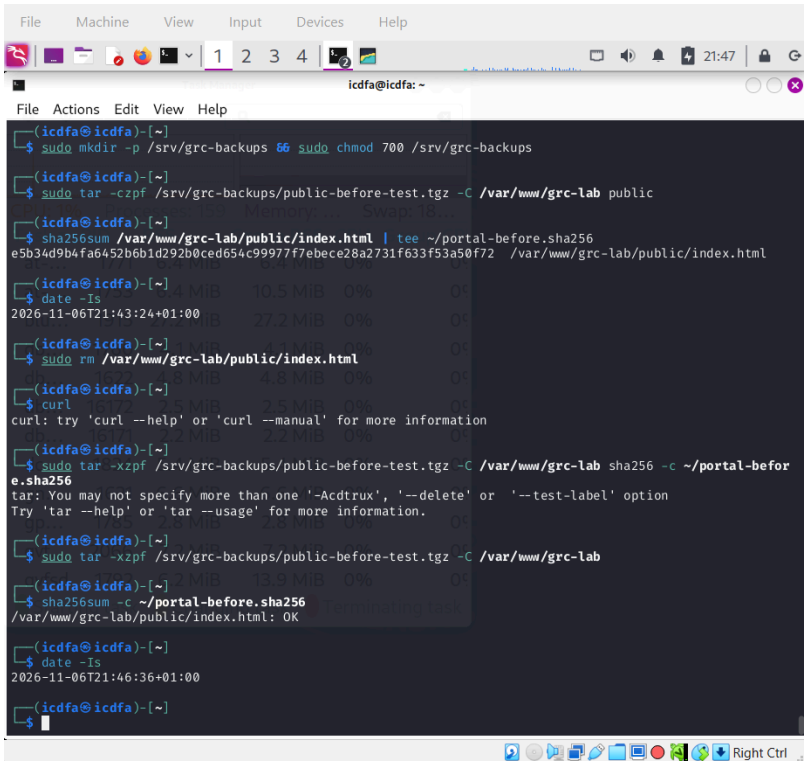
Correlate control evidence

Test	Source IP	Requested service	Expected
T01	10.0.2.4 (approved)	HTTP /public/	200
T02	10.0.2.4	HTTP /archive/	403
T03	10.0.2.4	HTTP /archive/dummy-records.txt	403
T04	None valid (attempt used 10.0.2.4)	HTTP /public/	Timeout
T05	Client	TCP/HTTP 8080	Closed or refused
T06	Server	SHA-256 of restored index.html	OK

Back up and recover the approved portal

```
e5b34d9b4fa6452b6b1d292b0ced654c99977f7ebece28a2731f633f53a50f72  /var/www/grc-lab/public/index.html
```





Measure	Value
Recovery exercise start (`date -Is`, before deletion)	21:43:24 +01:00
Restore verified (`date -Is` after `sha256sum -c` OK)	21:46:36 +01:00
Observed recovery interval	**192 seconds (3 min 12 s)**
Integrity check	`sha256sum -c`: OK (file identical to original)

Monitoring and operational handover

Check	Method	Owner	Frequency	Threshold	Escalation
Approved portal availability	`curl -fsS -o /dev/null -w '%{http_code}' http://SERVER/public/` from an approved client	Service Owner	Every 5 min	Not 200 on 2 consecutive checks	IT Operations Manager after 15 min; Risk Owner after 1 h
Unexpected open ports	`nmap -sT -p 1-1024,8080 SERVER` compared with the approved list (80 only)	Security Administrator	Daily	Any port other than 80 open; 8080 open is High	Ticket within 1 h; Risk Owner and Server Owner notified
Recovery-test success	Restore the backup to a temporary directory, run `sha256sum -c`, record elapsed time	Backup Owner	Monthly	100% hash match and restore under 15 min	Failed test is an incident; retest within 2 working days; review R4
Drift check: retired legacy service	`systemctl is-enabled grc-legacy, is-active grc-legacy, ss -lnt | grep :8080`, hash of the unit file	Systems Administrator	Daily, plus after every change	Unit enabled or active, or any listener on 8080	Immediate alert to Server Owner; change record required to explain it

4 Step 11: model transfer and acceptance

4.1 Transfer: managed backup versus local-only backup

	Local-only backup (as tested)	Managed backup (fictional offer)
First-year cost	No licence or service fee; staff labour excluded	$120 setup + 12 × $20 = **$360**
Protects against	File deletion or corruption on the host	Host loss, disk failure and local compromise (offsite copy), if the service is operated as contracted
Still depends on	Same host surviving	Provider performance, customer scope definition and restore testing

Proposed service clause

1. Provider duties. The Provider shall back up the designated directory daily, encrypt data in transit and at rest, store it separately from the Customer's server, retain 30 daily versions, monitor job status, notify the Customer's named contact of a failed job within 4 business hours and make a requested restoration available within 4 business hours.

2. Customer duties. The Customer shall define and maintain the backup scope, protect access credentials, act on failure notices, and perform and document a restoration test at least quarterly, including a SHA-256 comparison with the original. The Customer remains responsible for securing and patching its own server.

3. Evidence retention. Each party shall keep job logs, restoration-test records and notices for at least 12 months and provide them for audit on request.

4. Service limitation. The service restores data as it was at the last successful backup. It excludes data outside the agreed scope and corruption or malware present at backup time. Restoration times are targets, not guarantees, and the Provider's liability is limited to fees paid in the previous 12 months.

Limit of transfer. A contract moves operation of an offsite copy and some financial consequence to the provider. It does not remove the technical risk: the server can still be compromised, backups can still fail to restore, and the provider can fail. Residual R4 therefore stays on the register with the Service Owner.

4.2 Acceptance: plain HTTP on the isolated network

Risk considered	Traffic to the portal is unencrypted HTTP (no TLS), on the lab network, with dummy data only.
Risk owner	Northbridge Services IT Manager. **Approval simulated**, 2026-11-06.
Residual risk score	Likelihood 2 × impact 2 = **4, Low**. Interception needs an attacker already on the segment; UFW limits clients to 10.0.2.4; the data is fictional.
Rationale	Low residual risk with no real data, and a time-box. This is an assumed classroom appetite: Low may be accepted by the owner, Medium needs a treatment plan, High or above is escalated.
Expiry	14 days: **2026-11-20**.
Review date	2026-11-13, mid-point.
Triggers that void the acceptance	Any real, personal or confidential data; any connectivity beyond the isolated network (NAT, bridged or external); additional users, clients or credentials; use beyond the lab; loss of the UFW restriction.

Condition	The isolation assumption is **not yet evidenced** (Section 2, deviation 2). If isolation cannot be shown, do not accept: implement option C (TLS) first.

5 Step 12: costs, remaining risk and decision record

5.1 First-year cost of the options

First-year cost = setup + labour + annual recurring cost, using the fictional rates in the brief.

Option	Setup	Labour	Annual recurring	First-year cost
A Hardening work	$0	4 h × $25 = $100	$50 maintenance	**$150**
B Managed backup	$120	$0 (not specified)	12 × $20 = $240	**$360**
C TLS deployment	$0	3 h × $25 = $75	$25 maintenance	**$100**

Combination	First-year cost	Comment
A only	$150	Closes R1–R3 but leaves HTTP and same-host backup only
A + C	$250	Adds encryption in transit; backup remains local
A + B	$510	Adds offsite recovery; HTTP acceptance must expire in 14 days
A + B + C (recommended)	**$610**	Covers all four risks and the accepted HTTP exposure

Justification. A is the minimum: it turns the Section 3 configuration into verified controls for R1–R3. C is needed because the HTTP acceptance expires in 14 days and cannot be renewed once real data or wider access is in scope. B is justified by the illustrative ALE below and by the same-host limitation proven in Step 10. Benefits are not added across options, because they overlap and only B has a financial scenario. The cost of an option is not a reduction in an ordinal risk score.

Excluded costs: ongoing monitoring labour, restoration-test labour, staff training, storage and bandwidth beyond the service fee, TLS certificate fees if a paid CA is used, downtime during changes, management time and approvals, tax, and any lab hardware or licences.

5.2 Illustrative ALE for the backup scenario (every figure is an assumption)

Item	Working	Value (assumed)
Annual rate of occurrence (ARO)	assumption	0.2 per year
Loss per event, baseline	assumption	$5,000
Baseline ALE	0.2 × $5,000	**$1,000**
Loss per event with tested recovery	assumption	$1,000
Residual ALE	0.2 × $1,000	**$200**
Annual benefit	$1,000 − $200	**$800**
First-year cost of option B	$120 + 12 × $20	$360
First-year net benefit of B	$800 − $360	**$440**

5.3 Residual risk reassessment, R1–R4

A configured control is not automatically effective. Where the outcome was not tested, the residual score stays higher and the status says so.

ID	Residual L×I (band)	Evidence basis	Status	Owner	Review trigger
R1	2×4 = 8 (Medium). Would fall to 1×4 = 4 once verified	Avoidance scan and failed curl (Fig. 8); service state and `ss` after disable not captured; unit file defective (Fig. 4)	Configured	Systems Administrator	Any listener on 8080; `grc-legacy` enabled or active; unit file change
R2	2×4 = 8 (Medium). Would fall to 1×4 = 4 once verified	Archive moved, `go-rwx`, `deny all`, `autoindex off` written (Fig. 9); no 200/403 results; nginx inactive at 20:30	Configured	Document Server Owner	Any file appearing under the web root; nginx config change
R3	2×3 = 6 (Medium)	UFW rule visible in `status numbered` (Fig. 10–11); blocked-source test invalid; no `UFW BLOCK` logs	Configured	Network / Security Administrator	New allow rule; UFW disabled; unexpected client in logs
R4	2×3 = 6 (Medium)	Backup, hash and `sha256sum -c` OK; 192 s (Fig. 12–13). Same-host copy; no service-level check	File-level restore verified	Service and Backup Owner	Failed monthly restore test; any move to real data; decision on option B

5.4 Four-strategy decision record

Strategy	Applied to	Treatment	Status	Owner
Avoidance	R1	Retire the legacy endpoint (CR-01, simulated approval)	Unverified; fix unit file and capture `is-active` and `ss`	Systems Administrator
Mitigation	R2, R3, R4	Archive moved outside web root and denied; UFW allow-list with logging; local backup with hash-verified restore	Configured; R4 restore verified at file level	Server, Network and Backup Owners
Transfer	R4 residual	Managed offsite backup (option B, draft clause in 4.1); proposal only, nothing purchased	Proposed	Service Owner
Acceptance	Plain HTTP on isolated dummy-data network	Accept for 14 days (to 2026-11-20), then implement option C (TLS)	Proposed, simulated approval; isolation to be evidenced	IT Manager (risk owner)

6 Evidence index, gaps and re-run checklist

6.1 Screenshot-to-step map

Fig.	File	Time (WAT)	Step	What it shows
1	sudo_2.png	19:50	1	Package installation, needrestart summary
2	sudo_bash.png	19:59	1–2	`ip -br addr` (10.0.2.15/24); dummy content created
3	sudo_bash_2.png	20:03	2	Legacy unit creation; `enable` errors
4	sudo_bash_3.png	20:16	2	Invalid [Install[header; `status` shows Loaded: error, Active: running, PID 24407
5	sudo_bash_4.png	20:30	3	Nginx site config with `autoindex on`

Fig.	File	Time (WAT)	Step	What it shows
6	sudo_bash_5.png	20:30	3	`nginx -t` OK; reload failed, service not active
7	nmap_1.png	20:33–20:34	4	Baseline time; failed then successful scan; 80 and 8080 closed
8	nmap_2.png	20:42	6	Avoidance scan (both closed); curl to 8080 failed (7)
9	nmap_3.png	20:51	7	Archive moved, `go-rwx`, new nginx config; 8080 listener in `ss` output
10	nmap_4.png	21:33	8	UFW policy, allow rule, logging, enable, numbered status
11	nmap_5.png	21:36	8	Alias added; curl error 6 (empty `$SERVER_IP`)
12	nmap_6.png	21:43	9–10	Empty log checks; backup and SHA-256 recorded; `date -Is`
13	nmap_7_recovery_time.png	21:47	10	Delete, restore, `sha256sum -c` OK, closing `date -Is`